

CYB-041 : Cartographie et analyse des systèmes d'information

Introduction Générale du Cours

Dans un monde où les menaces informatiques se complexifient chaque jour, toute démarche de sécurité sérieuse commence par une question fondamentale : que devons-nous protéger ? Avant de déployer des pare-feu, de configurer des règles de filtrage ou de superviser des équipements dans un SOC, il est impératif de savoir précisément ce qui compose le Système d'Information (SI) de l'organisation, comment les différentes entités communiquent entre elles, et où se nichent les vulnérabilités exploitables par un attaquant.

Ce cours aborde la cartographie et l'analyse des systèmes d'information, deux disciplines indissociables qui constituent le socle de toute politique de cybersécurité cohérente. Sans cartographie, la défense devient aveugle. Sans analyse, elle reste superficielle. Ensemble, elles permettent de passer d'une posture réactive — subir les incidents — à une posture proactive — anticiper, prévenir et contenir.

Nous aborderons successivement les méthodes d'identification des actifs critiques, les techniques de cartographie des flux réseau, les approches d'analyse des vulnérabilités, puis nous nous intéresserons à la manière dont ces éléments s'articulent dans une architecture de défense en profondeur et au sein d'un SOC opérationnel.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Stratégique

- Comprendre l'importance de la cartographie dans une démarche de sécurité globale.
- Distinguer les différentes catégories d'actifs d'un SI et leur niveau de criticité.
- Appréhender les enjeux de la gestion des flux réseau et de la segmentation.

2. Compétences Techniques et Opérationnelles

- Réaliser un inventaire complet des actifs d'un SI avec des outils adaptés (Nmap, CMDB, Active Directory).
- Construire une matrice de flux réseau représentant les échanges autorisés et interdits.
- Identifier et classer les vulnérabilités à l'aide de scanners et du référentiel CVE/CVSS.
- Produire un schéma de cartographie réseau annoté et exploitable par une équipe SOC.

3. Expertise en Analyse de Risques

- Appliquer une méthode d'analyse de risque structurée (EBIOS RM, ISO 27005).

- Prioriser les actions de remédiation en fonction de la criticité et de l'exposition.
- Identifier les chemins d'attaque potentiels à partir d'une cartographie du SI.

4. Conformité et Documentation

- Produire une documentation de cartographie lisible, maintenable et conforme aux bonnes pratiques ANSSI.
- Comprendre le rôle de la cartographie dans les démarches de conformité (ISO 27001, NIS2, DORA).

Chapitre 1 : Fondements de la Cartographie des Systèmes d'Information

1. Pourquoi Cartographier ? Le Principe de Connaissance de Soi

La cartographie des systèmes d'information répond à un principe fondamental en sécurité : on ne peut protéger ce que l'on ne connaît pas. Cette vérité, souvent énoncée dans les cercles de cybersécurité, trouve son écho dans l'enseignement stratégique de Sun Tzu — connais ton terrain avant de livrer bataille. Dans le contexte d'un SI d'entreprise, le terrain, c'est précisément l'ensemble des composants matériels, logiciels, réseaux et données qui constituent l'infrastructure numérique.

Un SI non cartographié génère des angles morts : des machines oubliées, des services exposés à tort, des flux non documentés, des droits d'accès obsolètes. Ce sont autant de portes d'entrée pour un attaquant. La cartographie est donc un prérequis, non un luxe, pour tout RSSI souhaitant construire une défense cohérente.

2. Définition et Périmètre d'une Cartographie SI

Une cartographie du SI est une représentation structurée et documentée de l'ensemble des composants d'un système d'information : les actifs (serveurs, postes, équipements réseau, applications), les relations entre eux (flux de données, dépendances applicatives), et les interfaces avec l'extérieur (Internet, partenaires, cloud). Elle n'est pas figée : une cartographie est un document vivant, mis à jour à chaque changement significatif du SI.

On distingue généralement plusieurs niveaux de cartographie. La cartographie physique représente l'implantation géographique des équipements (salles serveurs, sites distants, cloud). La cartographie logique décrit les réseaux, sous-réseaux, VLAN et zones de sécurité. La cartographie applicative représente les applications, leurs dépendances et les données qu'elles traitent. Enfin, la cartographie des flux détaille les échanges entre composants avec les protocoles et ports associés.

3. Cadre Réglementaire et Normatif

La cartographie du SI n'est pas seulement une bonne pratique — elle est souvent une obligation. La directive NIS2 impose aux entités essentielles et importantes de maintenir une cartographie de leur SI. Le règlement DORA, applicable au secteur financier, exige une cartographie des actifs TIC critiques. L'ISO 27001 demande l'identification et la classification des actifs dans le cadre de son système de management de la sécurité de l'information.

En France, l'ANSSI recommande fortement la cartographie du SI dans son guide d'hygiène informatique et dans le cadre des labels SecNumCloud. Elle constitue également l'une des premières actions demandées lors d'un audit ou d'une homologation de sécurité. Ignorer cette étape revient à naviguer sans carte dans un environnement hostile.

Chapitre 2 : Identification et Classification des Actifs Critiques

1. Qu'est-ce qu'un Actif ? Taxonomie et Classification

Un actif du SI est tout composant qui présente une valeur pour l'organisation et qui nécessite, à ce titre, d'être protégé. Cette définition large englobe des réalités très diverses : un serveur de base de données, un poste de travail, une application web, un fichier de configuration, une identité numérique, voire une donnée sensible stockée dans un cloud public.

La classification des actifs répond à une double logique : d'une part, comprendre ce que l'on possède (inventaire), d'autre part, évaluer l'importance de chaque composant pour l'organisation (criticité). La criticité d'un actif se mesure généralement selon trois critères fondamentaux issus du triangle CID — Confidentialité, Intégrité, Disponibilité — que toute vulnérabilité ou incident peut affecter.

2. Tableau de Classification des Actifs

Le tableau suivant présente les principales catégories d'actifs rencontrées dans un SI d'entreprise, avec leur niveau de criticité et les propriétaires habituels :

Catégorie d'actif	Exemples	Criticité	Propriétaire
Serveurs critiques	AD, DNS, DHCP, PKI	Élevée	DSI / Infra
Applications métier	ERP, CRM, Messagerie	Élevée	DSI / MOA
Postes de travail	Portables, fixes	Moyenne	DSI / RH
Équipements réseau	Switches, routeurs, firewalls	Élevée	DSI / Réseau
Données sensibles	RH, Finance, R&D	Critique	DPO / RSSI
Systèmes industriels	SCADA, automates	Critique	DSI / Prod

3. Méthodes d'Inventaire des Actifs

L'inventaire des actifs est une opération qui combine des approches automatisées et humaines. Les outils de découverte réseau comme Nmap permettent de scanner l'ensemble des plages IP de l'organisation et d'identifier les machines actives, leurs systèmes d'exploitation et les services exposés. Une commande aussi simple que `nmap -sV -O 192.168.0.0/24` révèle en quelques minutes des dizaines d'équipements potentiellement non répertoriés.

Les outils de gestion des configurations (CMDB — Configuration Management Database) comme GLPI ou ServiceNow centralisent et maintiennent l'inventaire de manière structurée, en le reliant aux processus ITIL de gestion des changements. L'Active Directory, de son côté, fournit une vision précise des comptes utilisateurs, groupes, ordinateurs et objets de stratégie de groupe (GPO) au sein d'un environnement Windows.

Il ne faut pas négliger l'inventaire humain : des entretiens avec les responsables métier révèlent souvent des applications critiques non documentées (shadow IT), hébergées dans le cloud sans supervision de la DSI.

4. La Notion d'Actif Critique et la Priorisation

Tous les actifs ne se valent pas. Un poste de travail d'un stagiaire n'a pas le même impact potentiel qu'un contrôleur de domaine Active Directory. L'identification des actifs critiques consiste à isoler, au sein de l'inventaire complet, les composants dont la compromission ou l'indisponibilité entraînerait des conséquences majeures : arrêt de production, fuite de données personnelles, perte financière importante ou atteinte à la réputation.

La criticité peut être évaluée via une matrice combinant l'impact métier (que se passe-t-il si cet actif est indisponible ?) et la vraisemblance d'une attaque (est-il exposé, non patché, accessible depuis Internet ?). Cette priorisation guide ensuite directement les investissements en sécurité et l'ordre des remédiations.

Chapitre 3 : Cartographie des Flux Réseau

1. Comprendre les Flux Réseau dans un SI

Un flux réseau est une communication entre deux entités du SI, caractérisée par au moins quatre paramètres : une adresse source, une adresse destination, un protocole (TCP, UDP, ICMP) et un port. La cartographie des flux consiste à documenter l'ensemble de ces échanges pour comprendre qui communique avec qui, comment, et pourquoi.

Cette cartographie est indispensable pour plusieurs raisons. En premier lieu, elle permet de concevoir des règles de filtrage cohérentes pour les pare-feu : on ne peut écrire une politique de filtrage pertinente sans savoir quels flux sont légitimes. En second lieu, elle

constitue une référence pour la détection d'anomalies : tout flux non documenté dans la matrice est potentiellement suspect et doit être investigué par le SOC.

2. Matrice de Flux — Exemple Pratique

La matrice de flux est la représentation tabulaire des communications entre zones. Elle est le document de référence du pare-feu et de l'IDS/IPS. En voici un exemple appliqué à une infrastructure type PME :

Flux	Source	Destination	Protocole/Port	Autorisation
Accès web interne	LAN	Internet	TCP/443 HTTPS	Autorisé (proxy)
Accès ERP	LAN	Serveur ERP	TCP/8080	Autorisé
RDP administrateurs	VLAN Admin	Serveurs	TCP/3389	Restreint
SSH serveurs	Bastion	Serveurs	TCP/22	Autorisé
Télémétrie SCADA	Zone OT	Serveur SCADA	TCP/102	Isolé (diode)
E-mail entrant	Internet	Passerelle mail	TCP/25 SMTP	Filtré (AntiSpam)

3. Outils de Capture et d'Analyse des Flux

La construction d'une matrice de flux réelle ne se fait pas uniquement sur la base de déclarations — elle nécessite une observation du trafic en production. Plusieurs outils permettent cette observation.

Wireshark est l'analyseur de paquets de référence. Il capture le trafic sur une interface réseau et permet d'inspecter chaque paquet en détail, jusqu'au contenu applicatif. Son usage est particulièrement adapté pour la phase d'investigation initiale ou lors d'un incident. NetFlow, IPFIX et sFlow sont des protocoles de télémétrie réseau qui exportent des statistiques agrégées sur les flux (adresse source/destination, volume, durée) sans capturer le contenu des paquets. Ils sont plus adaptés à la supervision continue en production.

Les journaux de pare-feu constituent également une source précieuse : en analysant les logs sur une période de plusieurs semaines, on peut reconstituer une bonne partie de la cartographie des flux réels, y compris les flux bloqués qui révèlent des tentatives non autorisées.

4. Segmentation Réseau et Zones de Sécurité

La cartographie des flux révèle souvent une réalité inconfortable : dans de nombreuses organisations, tout le monde communique avec tout le monde, sans restriction. Cette absence de segmentation est l'une des principales facilités offertes aux attaquants pour le lateral movement — le déplacement latéral au sein du SI après une première compromission.

La bonne pratique consiste à segmenter le réseau en zones de sécurité homogènes, séparées par des contrôles d'accès stricts (pare-feu, ACL). On distingue classiquement la zone LAN (réseau interne utilisateurs), la zone DMZ (services exposés vers l'Internet), la zone serveurs (applications critiques), la zone OT/SCADA (systèmes industriels, isolée physiquement si possible), et la zone de management (accès aux consoles d'administration, accessible uniquement depuis un bastion).

Chapitre 4 : Analyse des Vulnérabilités

1. Définition et Cycle de Vie d'une Vulnérabilité

Une vulnérabilité est une faiblesse d'un composant du SI — logiciel, matériel ou organisationnelle — susceptible d'être exploitée par une menace pour causer un dommage. Elle se distingue de la menace (l'acteur ou événement susceptible d'exploiter la faiblesse) et du risque (la combinaison de la probabilité d'exploitation et de son impact).

Le cycle de vie d'une vulnérabilité commence par sa découverte (par un chercheur, un attaquant ou un outil automatisé), se poursuit par sa publication (dans le référentiel CVE, géré par MITRE et le NVD américain), puis par la publication d'un correctif par l'éditeur, et enfin par son application par l'administrateur. La fenêtre de temps entre la publication et le déploiement du correctif est critique : c'est pendant cette période que les attaquants tentent de l'exploiter (exploitation en masse des CVE récentes, aussi appelée n-day exploitation).

2. Le Référentiel CVE et le Score CVSS

Le référentiel CVE (Common Vulnerabilities and Exposures) est la base de données publique de référence pour les vulnérabilités connues. Chaque entrée est identifiée par un identifiant unique de la forme CVE-ANNÉE-NUMÉRO (exemple : CVE-2023-44487, correspondant à la vulnérabilité HTTP/2 Rapid Reset). Cette base est alimentée par les éditeurs logiciels, les chercheurs en sécurité et les CERT.

Le score CVSS (Common Vulnerability Scoring System) fournit une mesure standardisée de la sévérité d'une vulnérabilité, sur une échelle de 0 à 10. Il prend en compte la vecteur d'attaque (réseau, adjacent, local, physique), la complexité d'exploitation, les privilèges requis, l'interaction utilisateur nécessaire, et les impacts en termes de confidentialité, intégrité et disponibilité. Un score supérieur à 9 (critique) doit déclencher une action correctrice en urgence.

3. Tableau d'Analyse des Vulnérabilités — Exemple

Voici un exemple de tableau d'analyse des vulnérabilités tel qu'il pourrait être produit après un scan dans une infrastructure d'entreprise :

Vulnérabilité	CVSS	Actif concerné	Remédiation
---------------	------	----------------	-------------

CVE-2023-44487 (HTTP/2 Rapid Reset)	7.5	Serveur web Apache	Mise à jour, limitation de requêtes
Mot de passe par défaut	9.8	Switch réseau	Changement immédiat + MFA
RDP exposé sur Internet	8.1	Serveur RDS	Bastion SSH, désactivation exposition
VLAN hopping possible	6.5	Infrastructure switches	Hardening 802.1Q, port security
Patch OS manquant	7.8	Postes Windows	Déploiement WSUS/SCCM urgent

4. Outils de Scan et d'Analyse de Vulnérabilités

Plusieurs outils permettent d'automatiser la détection des vulnérabilités dans un SI. Nessus, de la société Tenable, est le scanner de vulnérabilités commercial le plus répandu dans le monde de l'entreprise. Il maintient une base de signatures régulièrement mise à jour et produit des rapports détaillés avec des suggestions de remédiation. OpenVAS (Open Vulnerability Assessment System) est son équivalent open source, maintenu par Greenbone Networks.

Ces outils fonctionnent de manière non intrusive (sans tentative d'exploitation réelle) ou intrusive (avec tentatives d'exploitation, à réserver aux environnements de test ou aux audits contractuels). Il est essentiel d'obtenir une autorisation formelle avant tout scan, même en réseau interne — scanner sans autorisation peut constituer une violation des politiques de sécurité et, dans certains cas, une infraction légale.

5. Analyse des Vulnérabilités Organisationnelles

Au-delà des failles techniques, l'analyse des vulnérabilités doit intégrer une dimension organisationnelle souvent négligée. Un mot de passe réutilisé par un administrateur, une procédure de gestion des accès non appliquée, une sauvegarde jamais testée, ou l'absence de procédure de réponse à incident constituent des vulnérabilités tout aussi réelles que les CVE techniques.

L'audit organisationnel, réalisé via des entretiens et l'examen de la documentation, permet de compléter l'image fournie par les scanners automatiques. C'est l'approche combinée — technique et organisationnelle — qui donne la vision la plus complète de la surface d'attaque réelle de l'organisation.

Chapitre 5 : Méthodologie Complète de Cartographie

1. Une Approche Structurée en Six Étapes

La réalisation d'une cartographie SI complète ne s'improvise pas. Elle suit une démarche structurée qui garantit l'exhaustivité des résultats et la qualité du livrable final. Le tableau suivant synthétise les six étapes clés de cette démarche :

Étape	Action	Outil / Méthode	Livrable
1. Périmètre	Définir le scope de la cartographie	Entretiens, documents DSI	Fiche de périmètre
2. Inventaire	Recenser tous les actifs SI	Nmap, CMDB, AD	Tableau d'actifs
3. Flux réseau	Identifier et documenter les échanges	Wireshark, NetFlow, entretiens	Matrice de flux
4. Vulnérabilités	Scanner et qualifier les failles	Nessus, OpenVAS, CVE	Rapport de vulnérabilités
5. Cartographie	Représenter graphiquement le SI	Draw.io, Visio, ANSSI-SAT	Schéma réseau annoté
6. Plan d'action	Prioriser les remédiations	Scoring CVSS + criticité	Plan de remédiation

2. Étape 1 : Définition du Périmètre

Avant toute chose, il est indispensable de délimiter précisément le périmètre de la cartographie. Cette délimitation répond à des questions simples mais essentielles : quels sites géographiques sont concernés ? Quelles entités juridiques ? Quels systèmes (on-premise uniquement, ou cloud également) ? Quels utilisateurs (internes seulement, ou partenaires et prestataires aussi) ?

Cette étape est réalisée en collaboration avec la direction, le RSSI et les responsables métier. Elle aboutit à la production d'une fiche de périmètre validée, qui servira de référence tout au long du projet. Sans périmètre clairement défini, la cartographie risque de dériver vers un exercice sans fin ou, au contraire, de passer à côté d'éléments critiques.

3. Étape 2 : Collecte et Consolidation des Données

La collecte des données s'appuie sur trois sources complémentaires. La documentation existante (schémas réseau, CMDB, contrats cloud, documentation applicative) fournit une base, souvent incomplète ou obsolète. Les outils de découverte automatique (Nmap, Qualys, outils SIEM) permettent de confronter la documentation à la réalité du réseau. Enfin, les entretiens avec les équipes techniques et les responsables métier révèlent les systèmes non documentés, les pratiques informelles et les dépendances cachées.

La consolidation de ces trois sources produit un inventaire unifié, souvent surprenant par le nombre d'actifs découverts par rapport à ceux initialement déclarés. Il n'est pas rare de découvrir lors d'un premier scan des équipements inconnus des équipes IT — vieux serveurs oubliés, équipements IoT non gérés, instances cloud non référencées.

4. Étape 3 : Représentation Graphique

La cartographie graphique est la traduction visuelle de l'inventaire et de la matrice de flux. Elle s'appuie sur des outils comme Draw.io (gratuit, en ligne), Microsoft Visio (standard en entreprise) ou des solutions spécialisées comme Netbrain ou les modules de cartographie intégrés aux SIEM modernes.

Une bonne cartographie graphique respecte plusieurs règles : elle distingue clairement les zones de sécurité par des couleurs ou des bordures différentes, elle identifie les flux critiques par des flèches différenciées (flux autorisés, flux filtrés, flux bloqués), elle indique les points de contrôle (pare-feu, proxies, IDS), et elle est lisible par un non-technicien — notamment par un RSSI ou un COMEX qui doit comprendre l'exposition de l'organisation.

Chapitre 6 : Cartographie et Cyberdéfense — Applications Pratiques

1. La Cartographie au Service de la Politique de Sécurité

Une politique de sécurité (PSSI) sans cartographie est une coquille vide. La cartographie alimente directement la PSSI en fournissant les données factuelles nécessaires à la définition des règles : quels actifs protéger en priorité, quels flux autoriser ou interdire, quelles zones nécessitent une authentification renforcée.

Concrètement, la cartographie permet de passer d'une règle de sécurité floue — « protéger les données sensibles » — à une règle opérationnelle précise : « le serveur de base de données RH (192.168.10.50, port 5432) n'est accessible que depuis les serveurs applicatifs RH (192.168.10.10/28), et ce trafic est journalisé et surveillé par le SIEM ». Cette précision est la condition sine qua non de la mise en œuvre effective de la politique.

2. Cartographie et Configuration des Pare-feu

La matrice de flux est le document source pour la rédaction des règles de pare-feu. Chaque ligne de la matrice correspond (ou devrait correspondre) à une ou plusieurs règles dans la politique de filtrage. Cette relation directe entre la cartographie et la configuration technique est ce qui garantit la cohérence de la défense.

Une bonne pratique consiste à annoter chaque règle de pare-feu avec une référence à la ligne de la matrice de flux qui la justifie, l'auteur de la règle, la date de création et le ticket de changement associé. Cette traçabilité facilite les audits, les révisions périodiques et le nettoyage des règles obsolètes — l'un des problèmes les plus fréquents en production, où les règles s'accumulent sans être jamais supprimées.

3. Cartographie et Détection des Menaces dans le SOC

Le SOC utilise la cartographie comme référentiel de normalité. Un analyste de niveau 1 qui voit une alerte SIEM concernant une connexion entre deux serveurs peut immédiatement vérifier dans la matrice de flux si ce flux est documenté. S'il ne l'est pas, il s'agit d'une anomalie à investiguer — potentiellement le signe d'un lateral movement ou d'une exfiltration de données.

Les règles de corrélation du SIEM s'appuient également sur la cartographie. Des règles comme « alerte si une connexion sortante est établie depuis un serveur de base de données vers une IP externe » ne sont significatives que si l'on sait, grâce à la cartographie, que ce serveur ne devrait jamais initier de connexion vers l'extérieur. Sans cette connaissance préalable, l'alerte perd toute pertinence.

4. Cartographie et Réponse à Incident

Lors d'un incident de sécurité, le temps est critique. Une cartographie à jour permet aux équipes de réponse à incident de comprendre en quelques minutes l'environnement de la machine compromise : quels systèmes elle peut atteindre, quelles données elle héberge, quels services en dépendent. Cette compréhension rapide est déterminante pour les décisions de containment — doit-on isoler la machine immédiatement, ou cela risque-t-il de couper un service critique ?

Sans cartographie, les équipes naviguent à l'aveugle et perdent un temps précieux en investigations préliminaires qui auraient pu être évitées. La cartographie est en ce sens un investissement dont le retour se mesure le jour où l'on en a le plus besoin.

Chapitre 7 : Maintien en Condition de la Cartographie

1. La Cartographie comme Document Vivant

L'erreur la plus fréquente en matière de cartographie est de la traiter comme un projet ponctuel : on cartographie le SI une fois, on range le document dans un dossier, et on oublie. Un an plus tard, la cartographie ne reflète plus la réalité — de nouveaux serveurs ont été déployés, des services cloud ont été souscrits sans validation de la DSI, des règles de pare-feu ont été ajoutées pour des besoins temporaires sans jamais être supprimées.

La cartographie doit être intégrée dans les processus de gestion des changements (Change Management). Tout déploiement d'un nouveau système, toute modification réseau significative, toute ouverture de flux doit automatiquement déclencher une mise à jour de la cartographie. Ce principe, simple dans sa formulation, nécessite une organisation et une gouvernance rigoureuses pour être appliqué en pratique.

2. Processus de Révision Périodique

Au-delà des mises à jour événementielles, la cartographie doit faire l'objet d'une révision périodique complète, idéalement semestrielle. Cette révision inclut une redécouverte réseau (scan Nmap sur l'ensemble des plages IP), une comparaison avec l'inventaire existant pour identifier les écarts, une revue des flux documentés par rapport aux logs de pare-feu réels, et une mise à jour du tableau de vulnérabilités via un nouveau scan.

La révision périodique peut également être l'occasion d'un audit de nettoyage des règles de pare-feu — identifier les règles avec zéro hit depuis plusieurs mois, les règles redondantes ou contradictoires, et les accès accordés à des comptes ou entités qui n'existent plus.

3. Automatisation et Outils de Gestion Continue

Des outils modernes permettent de partiellement automatiser la maintenance de la cartographie. Les SIEM comme Splunk, Microsoft Sentinel ou IBM QRadar intègrent des capacités de découverte d'actifs à partir des logs collectés. Des solutions comme Nessus.io ou Qualys VMDR permettent des scans de vulnérabilités continus avec mise à jour automatique d'un tableau de bord. Les outils CMDB modernes comme ServiceNow peuvent être intégrés aux systèmes de déploiement (Ansible, Terraform) pour mettre à jour automatiquement l'inventaire à chaque provisionnement.

L'objectif à terme est de disposer d'une cartographie dynamique, proche du temps réel, qui reflète en permanence l'état réel du SI et alerte sur toute dérive par rapport à la configuration de référence.

Chapitre 8 : Cas Pratique — Cartographie d'un SI d'Entreprise

1. Présentation du Scénario

La société fictive TechCorp SA est une PME de 150 salariés spécialisée dans l'édition de logiciels de gestion. Son SI héberge un ERP maison développé en interne, une messagerie Exchange hébergée sur site, un Active Directory centralisé, et un site web exposé sur Internet. Une partie des collaborateurs travaille en télétravail via un VPN SSL. La DSI, composée de 4 personnes, n'a jamais réalisé de cartographie formelle.

La direction a décidé de lancer une démarche de mise en conformité ISO 27001. La première action identifiée est la réalisation d'une cartographie complète du SI. Vous êtes le consultant cybersécurité mandaté pour cette mission.

2. Phase 1 : Découverte et Inventaire

La première action consiste à réaliser un scan Nmap sur les plages IP déclarées par la DSI (192.168.0.0/16 pour le réseau interne, 10.0.0.0/24 pour la DMZ). Le résultat révèle 87 machines actives, alors que la CMDB (tenue dans un simple fichier Excel) n'en répertorie que 62. Parmi les 25 équipements inconnus, on trouve : 8 imprimantes réseau non gérées, 3

Raspberry Pi utilisés par le département R&D pour des tests, 2 caméras IP connectées directement au réseau interne, 1 ancien serveur Windows Server 2008 R2 (en fin de support depuis 2020), et 11 équipements divers (téléphones IP, bornes WiFi).

Ce premier inventaire révèle une réalité souvent observée en pratique : le shadow IT est omniprésent, et des équipements vulnérables (le serveur 2008 R2, non patché depuis des années) coexistent avec l'infrastructure de production sans que personne n'en soit vraiment conscient.

3. Phase 2 : Analyse des Flux et Découverte des Anomalies

L'analyse des logs du pare-feu périmétrique sur les 30 derniers jours révèle plusieurs anomalies. Le serveur ERP initie régulièrement des connexions sortantes vers une IP externe (185.220.x.x) sur le port 443. Ce flux n'est pas documenté dans la matrice de flux. Après investigation, il s'avère que l'application ERP intègre un composant de télémétrie qui envoie des statistiques d'usage à l'éditeur — comportement légitime mais non documenté et non validé par la DSI.

Par ailleurs, on constate que le VLAN Administration est accessible depuis le VLAN Utilisateurs via le protocole WMI (port TCP/135), ce qui n'est pas souhaitable. Cette configuration résulte d'une règle de pare-feu ajoutée temporairement lors d'une migration trois ans auparavant et jamais supprimée.

4. Phase 3 : Livrables et Plan d'Action

À l'issue de la mission, les livrables produits comprennent le tableau d'inventaire des actifs (87 équipements, classés par criticité), la matrice de flux mise à jour (incluant les flux légitimes précédemment non documentés et la suppression des flux non justifiés), le schéma de cartographie réseau (représentation graphique par zones), le tableau des vulnérabilités (priorité critique : migration du Windows Server 2008 R2), et le plan de remédiation priorisé.

Les actions prioritaires identifiées sont les suivantes : isoler immédiatement le serveur Windows 2008 R2 ou planifier sa migration dans les 30 jours, supprimer la règle de pare-feu permettant l'accès WMI du VLAN Utilisateurs vers le VLAN Administration, documenter et valider formellement le flux de télémétrie ERP, et intégrer les 25 équipements découverts dans la CMDB.

Synthèse Générale du Module

Ce cours vous a conduit depuis les fondements conceptuels de la cartographie des systèmes d'information jusqu'à son application concrète dans une démarche de cyberdéfense opérationnelle. La progression logique adoptée reflète la réalité du terrain : on ne peut défendre que ce que l'on connaît, on ne peut analyser que ce que l'on a cartographié, et on ne peut superviser efficacement que ce que l'on a analysé.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que la cartographie n'est pas une fin en soi mais un outil au service de la décision. Une cartographie parfaitement réalisée mais jamais consultée est inutile ; une cartographie approximative mais régulièrement utilisée et mise à jour est précieuse. L'enjeu est donc autant organisationnel que technique : intégrer la cartographie dans les pratiques quotidiennes des équipes IT et sécurité.

La deuxième leçon est que les actifs critiques méritent une attention disproportionnée. Dans toute organisation, 20 % des actifs concentrent 80 % du risque. Identifier ces actifs, comprendre leurs flux, surveiller leurs vulnérabilités et anticiper les scénarios d'attaque qui les ciblent est le cœur du métier de l'analyste cybersécurité.

La troisième leçon est que la surface d'attaque évolue en permanence. Chaque nouveau service cloud, chaque nouveau partenaire, chaque nouvelle application métier étend potentiellement cette surface. La cartographie ne peut donc pas être un document statique : elle doit évoluer au rythme du SI, pilotée par des processus rigoureux et, autant que possible, assistée par des outils d'automatisation.

Glossaire

Terme	Définition
Actif critique	Composant dont la compromission ou l'indisponibilité aurait un impact majeur sur les activités de l'organisation.
CMDB	Configuration Management Database — base de données centralisant les informations sur les composants du SI et leurs relations.
CVE	Common Vulnerabilities and Exposures — référentiel public des vulnérabilités connues, géré par MITRE.
CVSS	Common Vulnerability Scoring System — score standardisé de sévérité d'une vulnérabilité (0 à 10).
DRP	Disaster Recovery Plan — plan de reprise d'activité définissant les procédures de restauration après sinistre.
EBIOS RM	Expression des Besoins et Identification des Objectifs de Sécurité Risk Manager — méthode française d'analyse de risque publiée par l'ANSSI.
Flux réseau	Communication entre deux entités du SI, caractérisée par une source, une destination, un protocole et un port.
IOC	Indicator of Compromise — artefact observable (hash, IP, domaine) signalant une compromission potentielle.
Lateral movement	Technique utilisée par un attaquant pour se déplacer progressivement au sein d'un SI après une intrusion initiale.
Matrice de flux	Document représentant l'ensemble des échanges autorisés entre les zones du SI.
PSSI	Politique de Sécurité du Système d'Information — document cadre définissant les règles et objectifs de sécurité de l'organisation.

RSSI	Responsable de la Sécurité des Systèmes d'Information — pilote la stratégie et la mise en œuvre de la sécurité SI.
SI	Système d'Information — ensemble des ressources (humaines, matérielles, logicielles) permettant de collecter, traiter et diffuser l'information.
Surface d'attaque	Ensemble des points d'entrée potentiels exploitables par un attaquant pour compromettre un système.
VLAN	Virtual Local Area Network — segmentation logique d'un réseau physique permettant d'isoler des groupes d'équipements.
Zero Trust	Modèle de sécurité n'accordant aucune confiance implicite, même en réseau interne, et imposant une vérification continue.